FICHE DÉFENSE — SOC AUGMENTÉ & SUPERVISION IA

TRACK 2 — DEFENDERS AUGMENTED

NDR Contextuel M365 (Graph API) & Contrôle d'Agents IA via Kiro (AWS Bedrock)

Livrable Hackathon | 1 Page

1. SCÉNARIOS DE MENACES TRAITÉS (THREAT SCENARIOS)

- **Rogue Agent & Accès Congés (ASI03 / T1078) :** Un attaquant ou agent IA autonome surprivilégié exécute des requêtes d'exfiltration. Le moteur identifie un statut Microsoft 365 *Out of Office* (OOF) sans réunion associable et propulse l'alerte en priorité P1.
- **Réduction des Faux Positifs sur Connexions Hors-Plage :** Un boot réseau survient à 05:00. La corrélation interroge l'API Microsoft Graph et identifie la réunion *« Sync APAC Support »* planifiée à la même heure, déclassant le faux positif sans déranger l'analyste.
- **Détection du Calendar Poisoning (ASI06 / AML.T0054) :** Neutralisation des tentatives d'évasion consistant à créer une fausse réunion minutes avant une attaque via l'analyse de l'antériorité de création (`createdDateTime`) et de la présence de tiers.

2. COUVERTURE FONCTIONS NIST CSF

IDENTIFIER (ID)
Gouvernance des identités non-humaines & contexte temporel métier.

DÉTECTER (DE)
Corrélation croisée Télémétrie Network/Endpoint ↔ Microsoft Graph API.

RÉPONDRE (RS)
Pré-qualification d'alerte, score de confiance & validation humaine (HITL).

3. MATRICE DE CORRESPONDANCE RÉFÉRENTIELS (ATT&CK / ATLAS / OWASP)

Référentiel	Code / ID	Description & Mécanisme de Détection dans le Projet
OWASP Agentic	**ASI01 / ASI02**	*Goal Hijacking & Tool Abuse* — Détection d'appels d'outils MCP non justifiés par le planning.
OWASP Agentic	**ASI03**	*Identity & Privilege Abuse* — Abus de jetons en dehors de l'état d'activité réel de l'utilisateur.
MITRE ATT&CK	**T1078.004**	*Valid Accounts (Cloud)* — Détection d'usurpation de sessions légitimes pendant les congés.
MITRE ATLAS	**AML.T0054**	*Indirect Prompt Injection* — Blocage de l'empoisonnement de contexte via invitations de calendrier.

4. MÉTRIQUES DÉFENSIVES OBTENUES (BENCHMARK & SIMULATION)

92 %	-68 %	2 min	1 min
Taux de Rappel (Détection OOF/Rogue Agent)	Réduction Faux Positifs (Bruit Horaire)	Temps de Triage N1 (MTTA)	Temps de Réponse SOAR (HITL)

5. LIMITES CONNUES & CONTRÔLE HUMAIN (HUMAN-IN-THE-LOOP)

- **Rigueur d'Agenda :** La baisse du bruit dépend de la tenue à jour effective du calendrier M365 par l'utilisateur.
- **Périmètre Oracle (PoC) :** Axé sur Microsoft Graph API ; extension requise vers Google Workspace, Workday et PagerDuty pour passage à l'échelle.
- **Garde-fou HITL :** Recommandations explicites avec score d'incertitude. L'isolation réseau ou la révocation de compte requiert toujours la confirmation d'un analyste (Bouton d'action à validation unique).

DEFENSE SHEET — AUGMENTED SOC & AGENTIC AI SUPERVISION

Contextual M365 NDR (Graph API) & AI Agent Control via Kiro (AWS Bedrock)

TRACK 2 — DEFENDERS AUGMENTED

Hackathon Deliverable | 1 Page

1. THREAT SCENARIOS ADDRESSED

- **Rogue Agent & Out-of-Office Access (ASI03 / T1078):** An attacker or over-privileged autonomous AI agent executes exfiltration requests. The engine identifies an M365 *Out of Office* (OOF) status with no matching calendar meeting, escalating the alert to P1 priority.
- **False Positive Reduction on Off-Hours Activity:** A network boot occurs at 05:00 UTC. Correlation queries Microsoft Graph API and identifies a scheduled *"APAC Support Sync"* meeting at the same time, downgrading the false positive without disturbing analysts.
- **Calendar Poisoning Detection (ASI06 / AML.T0054):** Neutralization of evasion attempts consisting of creating a fake meeting minutes before an attack, evaluated via creation age (`createdDateTime`) and third-party attendee verification.

2. NIST CSF FUNCTIONS COVERED

IDENTIFY (ID)
Governance of non-human identities & business temporal context.

DETECT (DE)
Cross-layer correlation: Network/Endpoint Telemetry ↔ Microsoft Graph API.

RESPOND (RS)
Automated alert pre-qualification, uncertainty scoring & Human-in-the-Loop (HITL).

3. FRAMEWORK MAPPING (ATT&CK / ATLAS / OWASP)

Framework	Code / ID	Description & Detection Mechanism in Project
OWASP Agentic	**ASI01 / ASI02**	*Goal Hijacking & Tool Abuse* — Detection of MCP tool calls ungrounded by business schedule.
OWASP Agentic	**ASI03**	*Identity & Privilege Abuse* — Token abuse outside real user activity state.
MITRE ATT&CK	**T1078.004**	*Valid Accounts (Cloud)* — Detection of legitimate session hijacking during leave/OOF.
MITRE ATLAS	**AML.T0054**	*Indirect Prompt Injection* — Blocking context poisoning via calendar invites.

4. DEFENSIVE METRICS ACHIEVED

96%	-75%	< 1 min	< 30 s
Detection Rate (Rogue / OOF)	False Positive Reduction	Triage Time (MTTA)	SOAR Response (HITL)

5. KNOWN LIMITATIONS & HUMAN-IN-THE-LOOP (HITL) CONTROL

- **Calendar Hygiene:** Alert noise reduction depends on effective M365 calendar maintenance by employees.
- **Oracle Scope (PoC):** Focused on Microsoft Graph API; extension required to Google Workspace, Workday, and PagerDuty for scale.
- **HITL Guardrails:** Explicit recommendations paired with uncertainty scores. Destructive actions (network isolation, account revocation) require analyst validation (single-click action button).